

CoinPort Disaster Recovery Plan

Field	Value
Document owner	CoinPort Engineering
Classification	Internal
Version	1.1
Effective date	2025-06-30
Next review	2026-06-30
Approver	CoinPort CTO

1. Purpose

This Disaster Recovery Plan (DRP) describes how CoinPort Pty Ltd will restore the CoinPort cryptocurrency exchange (www.coinport.com.au) to operating service following a disaster, prolonged outage, or material loss of data or infrastructure. It defines the recovery objectives, the responsibilities of each role, the technical procedures required to restore each service tier, and the testing and maintenance program that keeps the plan effective.

The CoinPort platform is built and operated using an **Infrastructure-as-Code (IaC)** model. The full set of services, configuration templates, container images, secrets policies, and deployment automation is held in repositories under the **CoinPort GitHub organisation** (github.com/coinport). Database state is held in **Microsoft Azure managed databases** (MySQL Flexible Server and PostgreSQL Flexible Server) where Azure performs automatic, point-in-time backups. Together these two pillars — Git-managed code and Azure-managed data — make a full rebuild of the platform a procedural, repeatable activity rather than an ad-hoc recovery.

2. Scope

This plan covers the production CoinPort exchange platform and its directly supporting components.

In scope

- The OpenDAX-derived service stack: Peatio, Barong, AppLogic, Sonic frontend, Tower admin, Gateway/Envoy, Rango, Traefik proxy, Vault, Redis, RabbitMQ, and all Peatio daemons (blockchain, deposit, withdraw, matching, order processor, trade executor, mailer, sidekiq workers, cron job).
- The orchestration layer in this repository ([opendax](#)): the Rake tasks, ERB templates, [config/app.yml](#), Docker Compose files, and Vault policy files that produce a deployable stack.
- Azure-hosted MySQL ([coinportex-prod.mysql.database.azure.com](#)) holding [peatio_production](#), [barong_production](#), and [sonic](#).
- Azure-hosted PostgreSQL instances supporting auxiliary services.
- AWS S3 KYC document storage ([peatio-kyc](#), region [ap-southeast-2](#)).
- Third-party integrations whose loss would degrade the exchange: SendGrid (email), Twilio (SMS), Didit and KYCAID (KYC), Cloudflare Turnstile (captcha), Auth0, Firebase, MaxMind, IPInfo, Monoova (AUD

payments), TradingView, Telegram and Microsoft Teams alerting webhooks, Freshworks support, Google Analytics / Tag Manager / Clarity.

- Custodial wallet infrastructure (deposit, hot, and warm wallets per asset).

Out of scope

- Disaster recovery for individual end-user devices.
- Recovery of office IT, staff laptops, and corporate productivity tools (handled by the corporate IT policy).
- Recovery of cold-storage wallet keys held under separate custody arrangements (covered by the CoinPort Key Custody Policy).

3. Definitions

Term	Meaning
Disaster	An unplanned event that prevents the production exchange from operating normally and that cannot be resolved by routine on-call response within 60 minutes.
RTO (Recovery Time Objective)	The maximum acceptable time between the disaster being declared and the affected service being restored.
RPO (Recovery Point Objective)	The maximum acceptable amount of data loss, measured as the time between the last good backup and the disaster.
MTPD (Maximum Tolerable Period of Disruption)	The longest interval the business can survive a service being unavailable before unrecoverable damage is sustained.
Warm site	A pre-provisioned secondary deployment that can be promoted to primary with configuration changes only.
Cold rebuild	A full redeployment from Git and Azure backups onto freshly provisioned infrastructure.
Incident Commander (IC)	The person with overall authority during the response to an incident.

4. Roles and responsibilities

Role	Primary	Backup	Responsibilities during a disaster
Incident Commander	Head of Engineering	CTO	Declares the disaster, owns decision-making, authorises recovery actions, runs the bridge.
Technical Lead — Platform	Lead Platform Engineer	Senior SRE	Drives infrastructure, container, and orchestration recovery. Owns Vault, Compose stack, Rake automation.
Technical Lead — Database	Lead Database Engineer	Senior SRE	Coordinates Azure database restore or failover. Verifies data integrity.

Role	Primary	Backup	Responsibilities during a disaster
Technical Lead — Wallets	Head of Treasury	Senior Wallet Engineer	Coordinates custodial wallet recovery and reconciliation; only person authorised to expose hot-wallet secrets during recovery.
Communications Lead	Head of Marketing	Head of Customer Support	Owns external communications: status page, social channels, customer email, regulator notifications.
Compliance Lead	Head of Compliance	DPO	Determines whether the event triggers AUSTRAC, ASIC, or OAIC reporting obligations.
Customer Support Lead	Head of Support	Senior Support Agent	Handles inbound customer queries, drafts FAQs, manages Freshdesk/Freshchat queues.
Executive Sponsor	CEO	CFO	Authorises external spend, regulator contact, and any decision to halt trading or freeze withdrawals.

A current contact list with phone numbers, personal email, and out-of-band messaging IDs is held in the Compliance Lead's encrypted store and in the CoinPort 1Password "DR Contacts" vault. It is reviewed quarterly.

5. Recovery objectives

The following objectives reflect the regulatory expectations applicable to a digital currency exchange operating under AUSTRAC registration and the operational tolerance agreed with the executive.

Tier	Service	RTO	RPO
0	Custodial wallets (hot, warm, cold) — funds safe and accounted	1 hour to confirm safety; full operational recovery 8 hours	0 (no acceptable loss)
1	Trading engine (Peatio matching, order processor, trade executor)	4 hours	5 minutes
1	Authentication (Barong, Auth0)	4 hours	5 minutes
1	Public website and trading frontend (Sonic, Traefik, Gateway)	4 hours	0 (stateless)
2	Deposit and withdrawal daemons	8 hours	5 minutes
2	KYC service (Didit / KYCAID)	8 hours	1 hour
2	Admin console (Tower)	12 hours	5 minutes
3	Reporting, BI (Superset), analytics	72 hours	24 hours
3	Mailer, SMS, support tooling	24 hours	24 hours

Service must not be partially restored at the cost of a Tier 0 obligation. If wallet integrity cannot be verified, trading will not be re-enabled regardless of how quickly the application stack returns.

6. Risk scenarios

The plan is written to address the following scenarios. Each is mapped to the recovery procedure that applies.

#	Scenario	Likelihood	Impact	Procedure
S1	Single application container or daemon crash	High	Low	\$10.1 Service-level recovery
S2	Single Docker host failure	Medium	High	\$10.2 Host rebuild
S3	Azure region-level outage affecting compute	Low	Critical	\$10.3 Region failover / cold rebuild in alternate region
S4	Azure MySQL or PostgreSQL corruption or accidental deletion	Low	Critical	\$10.4 Database restore
S5	Vault data loss or seal-key loss	Low	Critical	\$10.5 Vault recovery
S6	Complete loss of GitHub organisation access	Very low	Critical	\$10.6 Source control recovery
S7	Compromise of operator credentials, signing keys, or hot wallet keys	Low	Critical	\$10.7 Security incident — credential rotation
S8	Ransomware / destructive malware on production hosts	Low	Critical	\$10.8 Hostile compromise rebuild
S9	Loss of upstream third-party (SendGrid, Twilio, Didi, Auth0, Cloudflare)	Medium	Variable	\$10.9 Third-party degradation
S10	DDoS or sustained network attack	Medium	High	\$10.10 DDoS response
S11	Catastrophic loss of personnel (key person unavailable)	Low	Medium	\$10.11 Key-person continuity
S12	Natural disaster affecting Azure Australia East primary region	Very low	Critical	\$10.3 + \$10.4 combined

A full risk register with quantitative likelihood and impact scoring is maintained separately by the Compliance Lead and reviewed each quarter.

7. System architecture summary

A complete architectural reference lives in [README.md](#) and [CLAUDE.md](#) of this repository. The key facts a recoverer needs to know are:

- **Orchestration root:** this repository ([opendax](#)). `bundle install` then `rake render:config` regenerates every `config/` and `compose/` artefact from `templates/` and `config/app.yml`. This is how the platform is built and how it is rebuilt.

- **Single source of truth for configuration:** `config/app.yml`. All images, tokens, domains, credentials, and feature flags resolve from here. A clean copy from the protected `main` branch can rebuild the entire stack.
- **Compose layering:** there is no monolithic `docker-compose.yml`. The `.env` file sets `COMPOSE_FILE` to combine `proxy.yml`, `backend.yml`, `app.yml`, `gateway.yml`, `daemons.yml`, `monitoring.yml`, and optionally `superset.yml`.
- **Service dependency order** (used by `rake service:all[start]`): `proxy` → `backend` → `setup` (Vault init, render, kaisave) → `app` → `frontend` → `tower` → `utils` → `daemons`. Recovery must respect this order.
- **Secrets:** HashiCorp Vault holds runtime secrets. Per-component tokens are in `config/app.yml` under the `vault` key. Vault policy templates live in `templates/config/vault/*.hcl.erb`. Vault data is persisted in a Docker volume on the primary host.
- **Container endpoint:** every service is wrapped by Kaigara (`kaigara bundle exec ...`) which retrieves configuration from Vault at start-up.
- **Datastores:**
 - MySQL: Azure Database for MySQL Flexible Server, host `coinportex-prod.mysql.database.azure.com`, databases `peatio_production`, `barong_production`, `sonic`. Azure performs automated daily backups with 7-day point-in-time restore (PITR) configured.
 - PostgreSQL: Azure Database for PostgreSQL Flexible Server with the same Azure-managed backup regime.
 - Redis: ephemeral cache. No durable state required; rebuilt on restart.
 - RabbitMQ: durable queues only for non-state messaging; recreated on restart.
- **Object storage:** AWS S3 bucket `peatio-kyc` in `ap-southeast-2`. Versioning and cross-region replication are configured.
- **Edge:** Cloudflare DNS, WAF, and Turnstile CAPTCHA front Traefik. Cloudflare configuration is reproducible from Terraform in `terraform/`.

8. Backup inventory

Asset	Backup mechanism	Frequency	Retention	Restore mechanism	Verified
Source code, configuration templates, Rake tasks, Vault policies	Git, replicated to all developer clones; <code>coinport</code> GitHub organisation as authoritative	On every commit	Indefinite	<code>git clone</code> to any Docker host	Continuous
<code>config/app.yml</code> (rendered configuration with embedded secrets)	GitHub (private), encrypted backup in 1Password vault "CoinPort Production Config"	On every change	Indefinite	Copy to recovery host	Quarterly

Asset	Backup mechanism	Frequency	Retention	Restore mechanism	Verified
Container images	Docker Hub (coinport/* namespace) plus Azure Container Registry mirror	Per release tag	24 months	docker pull from registry	Continuous
MySQL (peatio_production , barong_production , sonic)	Azure automated backups (full + differential + log)	Continuous logs; full daily	7 days PITR (configurable up to 35)	Azure Portal / az mysql flexible-server restore	Quarterly
PostgreSQL	Azure automated backups	Continuous logs; full daily	7 days PITR	Azure Portal / az postgres flexible-server restore	Quarterly
Vault data	Encrypted nightly snapshot of Vault Docker volume to Azure Blob Storage (immutable, geo-redundant)	Daily at 02:00 AEST	30 days	Restore tarball over Vault volume, then unseal	Quarterly
Vault unseal keys (Shamir shares) and root token	Distributed across five named custodians; offline copies in safe-deposit box	On rotation only	Indefinite	Manual reconstitution	Annually
AWS S3 KYC documents	S3 versioning + cross-region replication to us-west-2	Continuous	Indefinite (retention by compliance schedule)	S3 console restore	Quarterly
Cloudflare configuration	Terraform state in terraform/ (Azure Blob backend with versioning)	On apply	Indefinite	terraform apply	On change
Wallet keys	Out of scope of this plan — covered by	n/a	n/a	Per Custody Policy	Annually

Asset	Backup mechanism	Frequency	Retention	Restore mechanism	Verified
	CoinPort Key Custody Policy. Hot-wallet seed recoverable from offline custodian envelopes				
Compose host configuration	Recreated by <code>rake</code> <code>render:config</code> from this repository — no host-specific state to back up	n/a	n/a	Re-render	Continuous

9. Communications plan

9.1 Internal communications

- **Primary bridge:** Microsoft Teams channel "CoinPort Incident Bridge". Webhook configured in `config/app.yml` under `teams.channel_url`.
- **Secondary bridge:** Telegram group, bot configured under `telegram.bot_token`.
- **Out-of-band fallback:** Signal group "CoinPort DR" — used only when corporate identity providers are unavailable. Membership maintained by the Compliance Lead.
- **Cadence:** the Incident Commander posts a written status update every 30 minutes for the duration of an active Tier 0 or Tier 1 incident, even if the only update is "no change".

9.2 External communications

Audience	Channel	Owner	Trigger
Customers	<code>status.coinport.com.au</code> (operated outside Azure on Cloudflare Pages, independent from the exchange)	Communications Lead	Within 30 minutes of declaration
Customers	Email broadcast via SendGrid; if SendGrid unavailable, fallback to AWS SES	Communications Lead	Within 2 hours for Tier 0/1
Customers	Twitter/X, Telegram public channel, Discord	Communications Lead	Within 30 minutes
Regulators	AUSTRAC and ASIC under their respective notification schedules; OAIC for personal-data incidents	Compliance Lead	As determined by the Compliance Lead, within statutory timeframes

Audience	Channel	Owner	Trigger
Banking partners	Direct phone and email to Monoova	Head of Treasury	If AUD payment processing affected
Insurers	Cyber-insurance broker	CFO	As soon as the disaster is declared
Press	No press contact unless authorised by the CEO	CEO	n/a

9.3 Holding statement

A pre-approved holding statement is stored in the "DR Communications" 1Password vault. It is to be issued within 30 minutes of declaration and updated as the incident progresses.

10. Recovery procedures

Each procedure assumes the Incident Commander has formally declared a disaster, opened the bridge, and recorded the start time. All recovery actions must be logged with timestamp and operator initials in the incident document for post-incident review.

10.1 Service-level recovery (S1)

1. Identify the affected service from monitoring (cAdvisor, node_exporter, application logs).
2. From the Compose host, run `rake service:<group>[restart]` for the affected service group (`app`, `daemons`, `frontend`, `backend`, `proxy`, `gateway`).
3. If the container is failing to start, inspect logs with `docker compose logs --tail=200 <service>` and verify Vault tokens are valid and Vault is unsealed.
4. If a single daemon is at fault, restart only that container: `docker compose restart <service>`.
5. Confirm health via the service's health endpoint and monitoring dashboards.
6. If the service does not recover within 30 minutes, escalate to §10.2.

10.2 Host rebuild (S2)

1. Provision a replacement Linux host (Ubuntu 22.04 LTS) sized per [docs/performance-tuning-4cpu-32gb.md](#) from the recovery image catalogue.
2. Install Docker Engine, Docker Compose plugin, Ruby 3.3.8, and `bundler`.
3. `git clone git@github.com:coinport/opendax.git` and check out the production tag recorded in the previous deployment record.
4. Restore `config/app.yml` from the 1Password "CoinPort Production Config" vault. **Do not** commit changes during recovery.
5. `bundle install`.
6. `rake render:config` to regenerate `config/` and `compose/`.
7. Restore the Vault data volume from the most recent Azure Blob snapshot (see §10.5). If Vault was healthy elsewhere, point this host at the existing Vault instead.
8. `rake service:all[start]`. Watch for orderly start-up: proxy → backend → app → frontend → daemons.

9. Update DNS / Cloudflare load balancer to point to the new host. TTLs are configured at 60 seconds for production records to enable rapid cutover.
10. Verify trading, login, deposit, withdrawal, and admin functionality before announcing recovery.

10.3 Region failover / cold rebuild (S3, S12)

This procedure is executed when the primary Azure region (Australia East) is unavailable.

1. The Incident Commander declares a regional disaster after confirming the outage with Azure Service Health and the Azure account team.
2. Provision compute in the secondary Azure region (Australia Southeast) using the Terraform configuration in `terraform/`. Override the `region` variable.
3. Restore Azure MySQL and PostgreSQL into the secondary region using geo-restore (see §10.4).
4. Follow §10.2 from step 2 onwards on the new host, pointing the rendered configuration at the geo-restored database endpoints.
5. Update Cloudflare DNS to direct `www.coinport.com.au` and `api.coinport.com.au` to the new region.
6. Verify Auth0, SendGrid, Twilio, and Didit allow-listed IP rules accept the new region's egress IPs. Update where necessary.
7. Halt withdrawals until the Database Lead confirms data integrity post-restore.
8. Resume trading only after the executive sponsor's authorisation.

10.4 Database restore (S4)

1. Determine the point-in-time target. The default is "latest restorable point" but compromise scenarios may require an earlier timestamp identified by the Compliance Lead.
2. In the Azure Portal, navigate to the affected Flexible Server and choose **Restore**.
 - For PITR within the retention window, use **Point-in-time restore**.
 - For region-loss events, use **Geo-restore**.
3. Restore to a **new server** — never overwrite the production server.
4. Once provisioned, validate the restored database:
 - Row counts on `peatio_production.trades`, `peatio_production.orders`, `barong_production.users`.
 - Latest `created_at` timestamps consistent with the chosen restore point.
 - Database Lead signs off in the incident document.
5. Update `database.host` in `config/app.yml`, re-render, and restart application services in dependency order.
6. The original server is retained read-only for forensic analysis. It must not be deleted until the Compliance Lead authorises.

10.5 Vault recovery (S5)

1. Stop application services that depend on Vault: `rake service:app[stop]`, `rake service:daemons[stop]`. Leave the proxy and a maintenance page running.
2. Stop the Vault container.
3. Replace the Vault Docker volume contents with the most recent encrypted snapshot from Azure Blob Storage.
4. Start the Vault container. Vault will start sealed.

5. The five named Shamir-share custodians convene (in person or via the DR Signal group) and provide their unseal keys to the Platform Lead until the threshold is met.
6. Once unsealed, verify each component token in `config/app.yml` is still valid via `vault token lookup`. Rotate any token whose validity is uncertain using `rake vault:load_policies`.
7. Restart application and daemon services in dependency order.

If Shamir shares are themselves lost: there is no recovery from this state. The platform must be re-initialised, all secrets rotated, and all integrations re-keyed. This is treated as a security incident under §10.7 in addition to a DR event.

10.6 Source control recovery (S6)

1. The CoinPort GitHub organisation is the authoritative source. If access is lost (account compromise, GitHub outage, or organisation deletion), Engineering reverts to local clones held by every active engineer.
2. Identify the most recent verified-signed commit on `main` for each affected repository by comparing local clones.
3. Push to a temporary GitHub organisation or to Azure DevOps as a contingency remote. Both contingency remotes are pre-provisioned and listed in the "DR Contacts" 1Password vault.
4. If the loss is account compromise, contact GitHub Support's enterprise security line (number in the DR vault) immediately and revoke all OAuth grants.
5. After recovery, audit commits made during the compromise window for unauthorised changes before redeploying.

10.7 Security incident — credential rotation (S7)

1. Treat this as a Tier 0 incident. The Compliance Lead is automatically engaged.
2. The Incident Commander, in consultation with the Head of Treasury, decides whether to halt withdrawals and/or trading.
3. Rotate, in this order:
 1. Vault root token and all component tokens (`rake vault:load_policies` after issuing a new root).
 2. Database passwords for MySQL and PostgreSQL.
 3. AWS access keys for the `peatio-kyc` bucket.
 4. SendGrid, Twilio, Didit, KYCAID, Auth0, Firebase, Cloudflare Turnstile, IPInfo, MaxMind, Monoova API credentials.
 5. Hot wallet keys — coordinated with the Treasury Lead. Cold wallets only if specifically compromised.
 6. JWT signing keys (RSA keypair generated by `lib/openssl/renderer.rb`).
4. Force-logout all customer sessions by rotating the Barong session secret.
5. Re-render configuration, redeploy, and verify.
6. Notify the OAIC if personal data was or may have been accessed; coordinate with the Compliance Lead.

10.8 Hostile compromise rebuild (S8)

1. Isolate affected hosts at the network level immediately. Do not power them off — preserve memory state for forensics.
2. Snapshot the affected disks via Azure Disk Snapshot for forensic handover.

3. Provision new clean hosts and follow §10.2 (host rebuild) using only artefacts validated by signed Git tags and signed container images.
4. Execute §10.7 (full credential rotation) in parallel.
5. Restore databases from a backup point **before** the earliest confirmed compromise. The Compliance Lead determines this point.
6. Forensic vendor engagement is authorised by the CFO; the broker for cyber insurance is engaged within the first hour.

10.9 Third-party degradation (S9)

Provider	Failure mode	Mitigation
SendGrid	Email outage	Switch SMTP provider to AWS SES (pre-configured failover credentials in Vault). Update <code>smtp.*</code> in <code>config/app.yml</code> , re-render, restart <code>mailer</code> .
Twilio	SMS outage	Disable SMS-required flows temporarily; require email-OTP only. Communications Lead notifies customers.
Didit / KYCAID	KYC outage	Pause new KYC submissions, queue customer requests, notify support. Trading for already-verified users continues.
Auth0	Login outage	Native Barong login remains available as a fallback. Update Sonic configuration to disable the Auth0 login button.
Cloudflare	Edge outage	Cloudflare orange-cloud bypass: switch DNS to grey-cloud (DNS-only) in Cloudflare; Traefik continues to terminate TLS. WAF protection is reduced — escalate monitoring.
Monoova	AUD payment outage	Pause AUD deposits and withdrawals; crypto trading continues. Notify customers.

10.10 DDoS response (S10)

1. Confirm with Cloudflare that the attack is detected (**Under Attack Mode** indicators, dashboard).
2. Engage Cloudflare's DDoS team via the enterprise number in the DR vault.
3. Enable **I'm Under Attack** mode on `coinport.com.au`.
4. Tighten WAF rules: block by ASN where attack origin is concentrated; raise CAPTCHA aggressiveness via Cloudflare Turnstile.
5. Communicate to customers via status page that defensive measures may add login friction.
6. Review and ease restrictions once the attack subsides; capture indicators for the post-incident review.

10.11 Key-person continuity (S11)

Every named role in §4 has a documented backup. Critical knowledge — Vault unseal custodianship, Cloudflare account ownership, Azure ownership, GitHub organisation ownership — is held by at least two distinct individuals. The Compliance Lead reviews this distribution at each quarterly DR review and is empowered to escalate to the CEO if any role is single-personned.

11. Wallet and funds integrity

For every Tier 0 incident, the Treasury Lead independently verifies fund integrity before trading is re-enabled.

1. Reconcile on-chain balances of all hot, warm, and cold wallets against the last known-good balance from `peatio_production.deposits`, `withdraws`, and `accounts`.
2. Confirm no unauthorised transactions occurred during the disaster window.
3. Sign off in the incident document.
4. Trading remains halted until this sign-off is recorded.

12. Plan testing

The plan is exercised on the schedule below. Each exercise is documented and any gaps drive a corrective action plan.

Test	Frequency	Owner	Method
Configuration restore from 1Password	Monthly	Platform Lead	Render <code>config/app.yml</code> on a clean VM; confirm <code>rake render:config</code> succeeds.
Database PITR	Quarterly	Database Lead	Azure portal restore to a sandbox server; row-count validation.
Vault snapshot restore	Quarterly	Platform Lead	Restore in a non-production project; unseal with test Shamir set.
Full cold rebuild (tabletop)	Bi-annually	Incident Commander	Walk-through with all role holders; no production change.
Full cold rebuild (live)	Annually	Incident Commander	Build a parallel environment from scratch in the secondary region; promote, demote, document.
DDoS playbook	Annually	Platform Lead	Tabletop with Cloudflare account team.
Communications plan	Bi-annually	Communications Lead	Issue a test status-page update and customer email to a test list.
Contact list verification	Quarterly	Compliance Lead	Confirm phone, email, Signal IDs for every named role and backup.

13. Plan maintenance

- The plan is reviewed every six months and after every incident, near-miss, significant architectural change, or change in personnel for any named role.
- The Compliance Lead is the document owner. Changes are made via pull request to `docs/disaster-recovery-plan.md` in this repository and reviewed by the CTO.
- Versioning follows the CoinPort document control standard. Each published version is tagged in Git as `drp/vX.Y` and a PDF rendering is attached to the release.
- Distribution: the markdown source is in this repository; the PDF rendering is attached to the corresponding GitHub release; the web version is published at `docs.coinport.com.au/disaster-recovery-plan` and is regenerated automatically on tag.

14. Post-incident review

Within ten business days of any disaster declaration, the Incident Commander runs a blameless post-incident review.

The review produces:

1. A timeline reconstructed from the incident document.
2. Confirmation of whether RTO and RPO were met for each affected tier.
3. A list of contributing factors (technical, procedural, organisational, third-party).
4. A list of corrective actions, each with a named owner and due date, tracked in the engineering issue tracker.
5. Updates to this plan, the runbooks, and the risk register where the review identifies gaps.
6. A summary report to the executive and to the Board's Risk Committee.

15. Appendices

Appendix A — Reference paths

Item	Location
Configuration source of truth	<code>config/app.yml</code>
Render engine	<code>lib/opendax/renderer.rb</code>
Vault automation	<code>lib/opendax/vault.rb</code> , <code>lib/tasks/vault.rake</code> , <code>templates/config/vault/*.hcl.erb</code>
Service orchestration	<code>lib/tasks/service.rake</code>
Compose layering	<code>compose/*.yaml</code> , selected via <code>.env COMPOSE_FILE</code>
Terraform IaC	<code>terraform/main.tf</code> , <code>terraform/variables.tf</code>
Performance sizing	<code>docs/performance-tuning-4cpu-32gb.md</code>
Install reference	<code>docs/aws-install.md</code> , <code>docs/ubuntu-install.md</code>
Security baseline	<code>SECURITY_AUDIT.md</code>

Appendix B — Repositories under the CoinPort GitHub organisation

The following repositories are required to fully rebuild the platform. All are mirrored to Azure DevOps as a contingency.

- `coinport/opendax` — orchestration (this repository)
- `coinport/peatio` — exchange engine
- `coinport/barong` — authentication
- `coinport/sonic` — frontend
- `coinport/applogic` — application logic gateway
- `coinport/rango` — websocket gateway
- `coinport/tower` — admin console fork

Container images for each are published to Docker Hub under the [coinport/](#) namespace and mirrored to Azure Container Registry.

Appendix C — Declared disaster checklist (one page)

The following abbreviated checklist is the first action of the Incident Commander on declaration. It is laminated and posted in the operations room.

- 1. Open the Teams Incident Bridge and start the incident document.
- 2. Confirm role-holders are present; activate backups for any missing primary.
- 3. Decide and announce: is trading halted? Are withdrawals halted?
- 4. Notify the executive sponsor, the Compliance Lead, and the cyber-insurance broker.
- 5. Identify the scenario from §6 and assign the corresponding procedure.
- 6. Set the next status-update deadline (30 minutes).
- 7. Begin the procedure. Log every action with time and operator.

Appendix D — Document history

Version	Date	Author	Change
1.0	2025-05-20	CoinPort Engineering	Initial issue.
1.1	2025-06-30	CoinPort Engineering	Removed sensitive information.

End of document.